QUANTUM SECURITY INTELLIGENCE

Отчёт об аудите безопасности и постквантовой готовности

bdk-wallet @ 09c677305139 · Bitcoin Dev Kit (bdk_wallet) — публичный репозиторий (пассивная проверка)

Организация	QSI
Дата отчёта	2026-10-29 18:40 UTC
Версия отчёта	1
Запуск аудита	294958d9-3cf8-4dc0-aa14-fb0ed8152e4c · Документальный аудит · 2026-10-29 18:40 UTC
Версия анализатора	qsi-engine 1.2.0
Профиль риска	Криптобиржа, кастодиан или кошелёк
SHA-256 содержимого	`b5aca581ea6518105c006631bb85a071e969e4986c59649d45daa4f0d385be01`
Ключ подписи (Ed25519, отпечаток SHA-256; подпись — отдельный файл report.sig.json)	`5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`

Содержание

1. Резюме для руководства
2. Область и границы проверки
3. Методология
4. Проверенные и непроверенные активы
5. Краткое описание архитектуры
6. Общая оценка состояния безопасности
7. Сводка находок по серьёзности
8. Подробное описание находок
9. Подтверждающие доказательства
10. Постквантовая оценка
11. Ограничения и допущения
12. План устранения проблем
13. Приоритеты на 30, 60 и 90 дней
14. Проверки после устранения
15. Использованные инструменты
16. Источники и нормативные документы
17. Приложения

Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.

Резюме для руководства

2	0	0	2	0
Всего находок	Критическая	Высокая	Средняя	Низкая

Классификация	Количество
Подтверждённая техническая уязвимость	0
Известная уязвимая версия компонента	0
Подтверждённая ошибка конфигурации	0
Потенциальный криптографический риск	0
Долгосрочный постквантовый риск	2
Рекомендация по улучшению	0
Недостаточность данных	0

Top 5

ID	Серьёзность	Подробное описание находок	Балл приоритета
QSI-2026-06654	Средняя	Квантово-уязвимый ECDSA: подпись транзакций и сообщений (6 файл(ов)) предварительно	35.6
QSI-2026-06653	Средняя	Квантово-уязвимый ECDSA: роль не определена (1 файл(ов)) предварительно	34.2

Неравенство Моски (x + y > z): x = 10, y = 5, z = 8 → при этом сценарии миграция завершится слишком поздно. z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Постквантовая зрелость: Уровень 0 из 4 — постквантовой криптографии нет. Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

Область и границы проверки

Режим: Документальный аудит

Репозиторий: https://github.com/bitcoindevkit/bdk_wallet @ 09c677305139e5478d57115a65e626320e809b0d — ссылки в доказательствах открывают строки на этом коммите.

Предоставленные входные данные

Файл	Размер	SHA-256	Маскирования
Cargo.toml	2628	2d120b9b42b9668a10a65777e06f8cd0e50ced9d254156d44fa8afd91c4c12ae	0
rust-toolchain.toml	66	6c7f7b59e2d60c8c326dc7ccda7bf17c045a261843cd780f4483ebf4beefb5b5	0
src/descriptor/checksum.rs	3799	b29b1b0e78b8c7d376562440d16116306d611518e2d6df11ef78c47e44fd8503	0
src/descriptor/dsl.rs	49483	a0a83c09fdc9044da2b66235ff0d730dd1096d93097c38a254d97e6dd6a5cf86	0
src/descriptor/error.rs	4831	bed2398e911f8610c72475a2bca78154e7f4996d1121425e5c5701ad1fcdc863	0
src/descriptor/mod.rs	42679	dc67e35d6a1707826ed032715296ec7538c70d1f700733925a763a18be2a3eee	0
src/descriptor/policy.rs	80162	febe1ea6f81ce382cd60e92b218fccbebfd38b149c5fea84d6a3e903d2d90d04	0
src/descriptor/template.rs	41092	102ca80557e8990159f44d692a00b6c2ce5c880db000b68e46f9de48934082c9	0
src/keys/bip39.rs	8663	1d960fd5099d71ed087028a58e285402825e1ec8a81d4da7bf9cf05568b6bc2d	0
src/keys/mod.rs	38964	4e121a877588ee09f62490018ef0ee8e553a5896d3a7f51c5d1c7d34f6b2ede0	0
src/lib.rs	1677	1cd85b831223a9a30be5c708a9a0a44c5a022470b73851df0dd551e3844bc82a	0
src/persist_test_utils.rs	20459	083844922e908fe0d2ca592d380a1bd85779ba6a6a3490f00a9e39dc829650f7	0
src/psbt/mod.rs	6201	4873a15ff6249883765c1398a9eff616a8d0872bd3a63f5fdb6f14e098731d28	0
src/psbt/params.rs	34169	ff804016efd16a5ed6089c3249420cf5dcae7b6ee303ff39e7d1a81276bb11c3	0
src/types.rs	8930	efd269d179855d1c79053495e20946cbdf8b76dc0c07b6b0c8492920d2aa25cd	0
src/wallet/changeset.rs	22137	16434c2c38edf2f70c5cd3c1365031677f1d21aab4ac6219f4040fe3bb1fcfef	0
src/wallet/coin_selection.rs	65337	9907123cdcf8b13f0d3343b4fd54d66a0580651e1cd7dbc3cc9d9bf8e1adae32	0
src/wallet/error.rs	18234	082a295f695836e3c222f97c1bb30746aeaf010b83b072037cd17cbec5d7a2d0	0
src/wallet/event.rs	6695	dab4b7f40a07e844f434c26ee436889e67c692d7f90bd85cb623215fbd27ccff	0
src/wallet/export.rs	48539	d88316237ddc9b44bacbd0f7968b9ff4802a5b29363ae9e7f031a34cd6590c63	0

src/wallet/locked_outpoints.rs	728	50186358b66ea69c976b5157fca4fdc282f4205571170a9a8bf35e1dde38376c	0
src/wallet/migration.rs	8338	3832932b79c8ba5b9a044ad3a232b8d5e92a4f04d8fd8356698af7adde734d19	0
src/wallet/mod.rs	172988	fa8b4eb9ca2a717c6dd8d3304ca9b9d8110f8f63fef7a66767702b76bcb2c023	0
src/wallet/params.rs	13563	498e9ae91e8c33393e1feb5cf3cb988ab35c242a72604af769e2f09a3a485d2b	0
src/wallet/persisted.rs	15430	20ff09cf976ce01c0b05773a80419ce9ae440e687ff34b2e850041812b875548	0
src/wallet/signer.rs	43474	3d26f404f3398db439261a2b91ee6a1ab1d03c7ef145d457a25e8e704b9d5b8e	0
src/wallet/tx_builder.rs	60874	97966cc1980737b980428b28eff586ce13b916f1a7b7eed1c9a6e4273613c1fb	1
src/wallet/utils.rs	9155	19712f4ca59a693f456d0882f03bcbbb2adaec188e7aede2f844adebb014db73	0

Методология

Аудит выполнен движком QSI 1.2.0. Каждый анализатор формирует факты (правило, параметры, доказательства); тексты находок генерируются из каталога правил. Источники методики указаны в разделе «Источники и нормативные документы».

Приоритизация: объяснимая взвешенная модель (серьёзность, вероятность эксплуатации, доступность атакующему, влияние на конфиденциальность/целостность/доступность с весами профиля «Криптобиржа, кастодиан или кошелёк», критичность актива, срочность, простота устранения) с множителем уверенности. CVSS v3.1 применяется только к техническим уязвимостям с определённым вектором. Для долгосрочных квантовых рисков используется неравенство Моски; их серьёзность ограничена уровнем «Средняя», и они никогда не представляются как эксплуатируемые уязвимости.

Классификация находок: подтверждённая техническая уязвимость; известная уязвимая версия компонента (версия зависимости названа в бюллетене; затронутый код может не вызываться — это проверяется отдельно, а подтверждённая проверкой становится уязвимостью); подтверждённая ошибка конфигурации; потенциальный криптографический риск; долгосрочный постквантовый риск; рекомендация по улучшению; недостаточность данных. Находки на основе эвристик помечены как предварительные; решения аналитика показаны рядом с находками.

Покрытие проверок

Область	Статус	Подробности
dependencies	проверено	Cargo.toml: 20 dependencies parsed (0 pinned)
source_code	проверено	src/descriptor/checksum.rs: 89 lines scanned with 16 rule patterns and 123 registry patterns; 52 lines in #[cfg(test)] modules ignored
source_code	проверено	src/descriptor/dsl.rs: 1276 lines scanned with 16 rule patterns and 123 registry patterns; 460 lines in #[cfg(test)] modules ignored
source_code	проверено	src/descriptor/error.rs: 139 lines scanned with 16 rule patterns and 123 registry patterns
source_code	проверено	src/descriptor/mod.rs: 1049 lines scanned with 16 rule patterns and 123 registry patterns; 424 lines in #[cfg(test)] modules ignored
source_code	проверено	src/descriptor/policy.rs: 1956 lines scanned with 16 rule patterns and 123 registry patterns; 779 lines in #[cfg(test)] modules ignored
source_code	проверено	src/descriptor/template.rs: 1080 lines scanned with 16 rule patterns and 123 registry patterns; 445 lines in #[cfg(test)] modules ignored
source_code	проверено	src/keys/bip39.rs: 236 lines scanned with 16 rule patterns and 123 registry patterns; 84 lines in #[cfg(test)] modules ignored
source_code	проверено	src/keys/mod.rs: 1159 lines scanned with 16 rule patterns and 123 registry patterns; 112 lines in #[cfg(test)] modules ignored
source_code	проверено	src/lib.rs: 63 lines scanned with 16 rule patterns and 123 registry patterns
source_code	проверено	src/persist_test_utils.rs: 580 lines scanned with 16 rule patterns and 123 registry patterns

source_code	проверено	src/psbt/mod.rs: 170 lines scanned with 16 rule patterns and 123 registry patterns; 81 lines in #[cfg(test)] modules ignored
source_code	проверено	src/psbt/params.rs: 902 lines scanned with 16 rule patterns and 123 registry patterns; 231 lines in #[cfg(test)] modules ignored
source_code	проверено	src/types.rs: 295 lines scanned with 16 rule patterns and 123 registry patterns; 73 lines in #[cfg(test)] modules ignored
source_code	проверено	src/wallet/changeset.rs: 528 lines scanned with 16 rule patterns and 123 registry patterns; 101 lines in #[cfg(test)] modules ignored
source_code	проверено	src/wallet/coin_selection.rs: 1833 lines scanned with 16 rule patterns and 123 registry patterns; 1107 lines in #[cfg(test)] modules ignored
source_code	проверено	src/wallet/error.rs: 488 lines scanned with 16 rule patterns and 123 registry patterns
source_code	проверено	src/wallet/event.rs: 186 lines scanned with 16 rule patterns and 123 registry patterns
source_code	проверено	src/wallet/export.rs: 1122 lines scanned with 16 rule patterns and 123 registry patterns; 424 lines in #[cfg(test)] modules ignored
source_code	проверено	src/wallet/locked_outpoints.rs: 26 lines scanned with 16 rule patterns and 123 registry patterns
source_code	проверено	src/wallet/migration.rs: 227 lines scanned with 16 rule patterns and 123 registry patterns; 123 lines in #[cfg(test)] modules ignored
source_code	проверено	src/wallet/mod.rs: 4207 lines scanned with 16 rule patterns and 123 registry patterns; 247 lines in #[cfg(test)] modules ignored
source_code	проверено	src/wallet/params.rs: 373 lines scanned with 16 rule patterns and 123 registry patterns
source_code	проверено	src/wallet/persisted.rs: 432 lines scanned with 16 rule patterns and 123 registry patterns
source_code	проверено	src/wallet/signer.rs: 1208 lines scanned with 16 rule patterns and 123 registry patterns; 228 lines in #[cfg(test)] modules ignored
source_code	проверено	src/wallet/tx_builder.rs: 1573 lines scanned with 16 rule patterns and 123 registry patterns; 560 lines in #[cfg(test)] modules ignored
secrets	проверено	src/wallet/tx_builder.rs: 1 redacted value(s) not reported (comments, test modules, fixture declarations, placeholders, values the source annotates as published, or hex values not bound to a secret name)
source_code	проверено	src/wallet/utils.rs: 281 lines scanned with 16 rule patterns and 123 registry patterns; 115 lines in #[cfg(test)] modules ignored
osv_advisories	не проверено	no exactly pinned versions to query

Проверенные и непроверенные активы

Предоставленные входные данные: Cargo.toml, src/descriptor/checksum.rs, src/descriptor/dsl.rs, src/descriptor/error.rs, src/descriptor/mod.rs, src/descriptor/policy.rs, src/descriptor/template.rs, src/keys/bip39.rs, src/keys/mod.rs, src/lib.rs, src/persist_test_utils.rs, src/psbt/mod.rs, src/psbt/params.rs, src/types.rs, src/wallet/changeset.rs, src/wallet/coin_selection.rs, src/wallet/error.rs, src/wallet/event.rs, src/wallet/export.rs, src/wallet/locked_outpoints.rs, src/wallet/migration.rs, src/wallet/mod.rs, src/wallet/params.rs, src/wallet/persisted.rs, src/wallet/signer.rs, src/wallet/tx_builder.rs, src/wallet/utils.rs

Не проверено

- osv_advisories: no exactly pinned versions to query

Краткое описание архитектуры

Static review of the source tree bdk-wallet at 09c677305139e5478d57115a65e626320e809b0d. 28 files analysed; of 84 files, 21 are test, fuzzing, benchmark or example code and were left out, 35 are not read by any analyzer, 0 exceed the per-file limit and 0 did not fit the total limit. 29 files in build-output or dependency-cache directories (.git, .hg, .venv, __pycache__, build, dist, node_modules, target, vendor, venv) were not read. No requests were sent to the owner's systems.

Общая оценка состояния безопасности

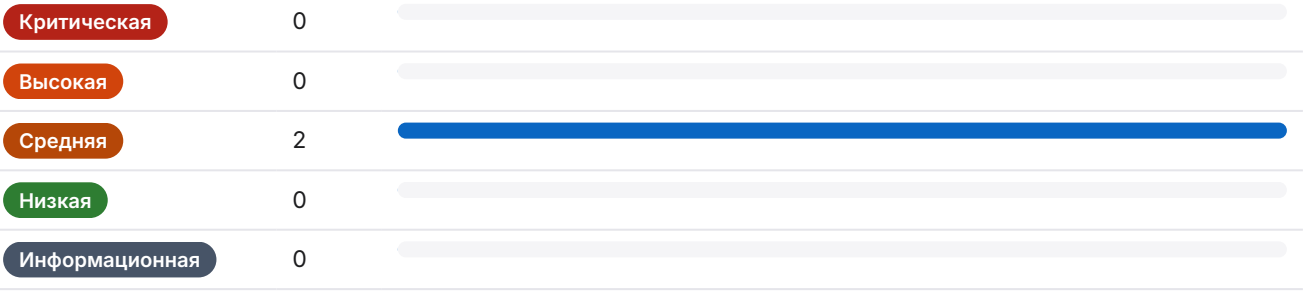
100
Ориентировочный индекс состояния (0–100)

70.0%
Доля квантово-уязвимых элементов инвентаризации

10
Криптографическая инвентаризация

Рассчитан по находкам в области проверки (подтверждённые и потенциальные проблемы, взвешенные по серьёзности). Ориентировочный; не сравним между аудитами с разной областью.

Сводка находок по серьёзности



ID	Подробное описание находок	Классификация	Серьёзность	Уверенность
QSI-2026-06654	Квантово-уязвимый ECDSA: подпись транзакций и сообщений (6 файл(ов))	Долгосрочный постквантовый риск	Средняя	Средняя, предварительно
QSI-2026-06653	Квантово-уязвимый ECDSA: роль не определена (1 файл(ов))	Долгосрочный постквантовый риск	Средняя	Средняя, предварительно

Подробное описание находок

QSI-2026-06654 · CODE-QV-ASYMMETRIC

Средняя

Квантово-уязвимый ECDSA: подпись транзакций и сообщений (6 файл(ов))

Долгосрочный постквантовый риск | Уверенность: Средняя | предварительно — требует дополнительной проверки

15 упоминаний ECDSA в 6 файл(ах), например src/descriptor/mod.rs:27. Роль по путям, именам функций и соседнему коду: подпись транзакций и сообщений. CRQC восстанавливает закрытый ключ по уже известному открытому (в блокчейне после первой траты, при повторном использовании адреса): средствам и подтверждениям под этими ключами нужен путь миграции.

Затронутый актив	source-code:ECDSA:transaction_signing
Источник данных	src/descriptor/mod.rs
Метод обнаружения	Сопоставление регулярных выражений с криптографическими API; роль определяется по словам в путях, именам охватывающих функций и строкам рядом с совпадениями.
Анализатор	source_code 1.2.0 · 2026-10-29 18:40 UTC
Балл приоритета	35.6 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=10.0, y=5.0, z=8.0 → при этом сценарии миграция завершится слишком поздно

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Долгосрочный риск зависит от назначения: подписи (подлинность до миграции) или обмен ключами/шифрование (ретроспективная расшифровка записанных данных).

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Откройте src/descriptor/mod.rs:27 и проверьте приведённые строки; остальные файлы перечислены в доказательствах.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

file_excerpt · src/descriptor/mod.rs · line 27 · SHA-256 ef180cf867bd24db… · Файл dc67e35d6a170782…

```
26 |     key::XOnlyPublicKey,
27 |     psbt, secp256k1, taproot,
28 | };
```

file_excerpt · src/descriptor/mod.rs · line 65 · SHA-256 d5a40e720e97a4a0… · Файл dc67e35d6a170782…

```
64 | /// [`psbt::Output`]: bitcoin::psbt::Output
65 | pub type HdKeyPaths = BTreeMap<secp256k1::PublicKey, KeySource>;
66 |
```

file_excerpt · src/keys/mod.rs · line 29 · SHA-256 f01d9a434353349a… · Файл 4e121a877588ee09…

```
28 |     key::XOnlyPublicKey,
29 |     secp256k1::{self, Secp256k1, Signing},
30 | };
```

file_excerpt · src/keys/mod.rs · line 752 · SHA-256 37ac35ee8c3d1e6d… · Файл 4e121a877588ee09…

```
751 | impl<Ctx: ScriptContext> GeneratableKey<Ctx> for PrivateKey {
752 |     type Entropy = [u8; secp256k1::constants::SECRET_KEY_SIZE];
753 |
```

file_excerpt · src/keys/mod.rs · line 761 · SHA-256 36e760a8c0331fa1… · Файл 4e121a877588ee09…

```
760 |     ) -> Result<GeneratedKey<Self, Ctx>, Self::Error> {
761 |         let inner = secp256k1::SecretKey::from_slice(&entropy)?;
762 |         let private_key = [REDACTED] {
```

file_excerpt · src/persist_test_utils.rs · line 13 · SHA-256 9dc96eec69fd8582… · Файл 083844922e908fe0…

```
 12 |     Address, Amount, Network, OutPoint, ScriptBuf, Transaction, TxIn, TxOut, Txid, absolute,
 13 |     secp256k1::Secp256k1, transaction,
 14 | };
```

file_excerpt · src/wallet/mod.rs · line 42 · SHA-256 0d90e97bca9e9048… · Файл fa8b4eb9ca2a717c…

```
 41 |     psbt,
 42 |     secp256k1::Secp256k1,
 43 |     sighash::{EcdsaSighashType, TapSighashType},
```

file_excerpt · src/wallet/mod.rs · line 83 · SHA-256 ac382ef2741110c1… · Файл fa8b4eb9ca2a717c…

```
 82 | #[cfg(all(bdk_wallet_unstable, feature = "bdk-tx", feature = "std"))]
 83 | use bitcoin::secp256k1::rand;
 84 | #[cfg(all(bdk_wallet_unstable, feature = "bdk-tx"))]
```

file_excerpt · src/wallet/signer.rs · line 101 · SHA-256 221a595769960622… · Файл 3d26f404f3398db4…

```
100 | use bitcoin::psbt::PsbtSighashType;
101 | use bitcoin::secp256k1::Message;
102 | use bitcoin::sighash::{EcdsaSighashType, TapSighash, TapSighashType};
```

file_excerpt · src/wallet/signer.rs · line 105 · SHA-256 584441038c7a33d3… · Файл 3d26f404f3398db4…

```
104 | use bitcoin::{ecdsa, psbt, sighash, taproot};
105 | use bitcoin::{key::TapTweak, key::XOnlyPublicKey, secp256k1};
106 |
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня. Эвристическое сопоставление шаблонов в исходном тексте без анализа потоков данных. Контекст использования (влияет ли на безопасность) требует ручного подтверждения; находка предварительная.

РЕКОМЕНДАЦИЯ

Следите за постквантовыми планами каждой сети, не используйте открытые ключи повторно и держите подписание готовым к постквантовым схемам по мере их принятия сетями.

ПОВТОРНАЯ ПРОВЕРКА

Повторите инвентаризацию после рефакторинга.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards; M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018)

QSI-2026-06653 · CODE-QV-ASYMMETRIC

Средняя

Квантово-уязвимый ECDSA: роль не определена (1 файл(ов))

Долгосрочный постквантовый риск | Уверенность: Средняя | предварительно — требует дополнительной проверки

8 упоминаний ECDSA в 1 файл(ах), например src/descriptor/dsl.rs:69. Роль по путям, именам функций и соседнему коду: роль не определена. По коду не видно, что защищают ключи; приоритет определит проверка.

Затронутый актив	source-code:ECDSA:general
Источник данных	src/descriptor/dsl.rs
Метод обнаружения	Сопоставление регулярных выражений с криптографическими API; роль определяется по словам в путях, именам охватывающих функций и строкам рядом с совпадениями.
Анализатор	source_code 1.2.0 · 2026-10-29 18:40 UTC
Балл приоритета	34.2 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=10.0, y=5.0, z=8.0 → при этом сценарии миграция завершится слишком поздно

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Долгосрочный риск зависит от назначения: подписи (подлинность до миграции) или обмен ключами/шифрование (ретроспективная расшифровка записанных данных).

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Откройте src/descriptor/dsl.rs:69 и проверьте приведённые строки; остальные файлы перечислены в доказательствах.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

file_excerpt · src/descriptor/dsl.rs · line 69 · SHA-256 691d199558b76f9b... · Файл a0a83c09fdc9044d...

```
68 |         use $crate::keys::{DescriptorKey, IntoDescriptorKey};
69 |         let secp = $crate::bitcoin::secp256k1::Secp256k1::new();
70 |
```

file_excerpt · src/descriptor/dsl.rs · line 93 · SHA-256 3b81db41c446a7e0... · Файл a0a83c09fdc9044d...

```
92 |
93 |         let secp = $crate::bitcoin::secp256k1::Secp256k1::new();
94 |
```

file_excerpt · src/descriptor/dsl.rs · line 266 · SHA-256 7bd931f6b2a9bdd2... · Файл a0a83c09fdc9044d...

```
265 |     ( $build_desc:expr, sortedmulti_vec ( $thresh:expr, $keys:expr ) ) => ({
266 |         let secp = $crate::bitcoin::secp256k1::Secp256k1::new();
267 |         $crate::keys::make_sortedmulti($thresh, $keys, $build_desc, &secp)
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня. Эвристическое сопоставление шаблонов в исходном тексте без анализа потоков данных. Контекст использования (влияет ли на безопасность) требует ручного подтверждения; находка предварительная.

РЕКОМЕНДАЦИЯ

Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема; введите уровень абстракции для криптогибкости.

ПОВТОРНАЯ ПРОВЕРКА

Повторите инвентаризацию после рефакторинга.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards; M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018)

Подтверждающие доказательства

ID	Тип	Источник данных	SHA-256
QSI-2026-06654	file_excerpt	src/descriptor/mod.rs (line 27)	ef180cf867bd24db405b6f62715cc6bacefb4ea00699f88a2d8002dd7fed7109
QSI-2026-06654	file_excerpt	src/descriptor/mod.rs (line 65)	d5a40e720e97a4a0cdc2072db1cbba967e65aec2cce2f274a6af858766042692
QSI-2026-06654	file_excerpt	src/keys/mod.rs (line 29)	f01d9a434353349a6b6c822607be17e5ef9d9909b1cb7843df81bf5f81553427
QSI-2026-06654	file_excerpt	src/keys/mod.rs (line 752)	37ac35ee8c3d1e6dda9532f4c653b5a46af25094cf31a2e08c0b5d1aeac18b9c
QSI-2026-06654	file_excerpt	src/keys/mod.rs (line 761)	36e760a8c0331fa1be0c095357d061ab5b330c723eac360f5a06541233f7a312
QSI-2026-06654	file_excerpt	src/persist_test_utils.rs (line 13)	9dc96eec69fd85823ed036165e6e0888d67b22ab83d6b91bf15836e3e400e6e3
QSI-2026-06654	file_excerpt	src/wallet/mod.rs (line 42)	0d90e97bca9e904888a1c282f9a14a5eea863865793320ed516c80a35fc8669a
QSI-2026-06654	file_excerpt	src/wallet/mod.rs (line 83)	ac382ef2741110c1892fac952ee277ed95ceec7b6c0331ac74aad2e7086677f5
QSI-2026-06654	file_excerpt	src/wallet/signer.rs (line 101)	221a595769960622a09f27edb82a9a01b8981cf57b87606433b94c74f198377b
QSI-2026-06654	file_excerpt	src/wallet/signer.rs (line 105)	584441038c7a33d375b26bc0046e2448660f2f3bc13b1b35f5245653b696d134
QSI-2026-06653	file_excerpt	src/descriptor/dsl.rs (line 69)	691d199558b76f9bd93ca983b6b47b730778df0c9dee289cc46be1a64fd2a6ea
QSI-2026-06653	file_excerpt	src/descriptor/dsl.rs (line 93)	3b81db41c446a7e02654911ae241096e77559545c3627d19e93112954bfd1e34
QSI-2026-06653	file_excerpt	src/descriptor/dsl.rs (line 266)	7bd931f6b2a9bdd2060714543163829831788977 81b2b4931255242417f60a55

Постквантовая оценка

	Обмен ключами (x — сколько данные должны оставаться конфиденциальными; «собери сейчас, расшифруй потом»)	Подписи (x — сколько подписи и ключи должны оставаться доверенными)
Срок жизни данных/ключей x	10	10
Время миграции y	5	5
Принятое число лет до CRQC z	8 (early)	8
x + y − z	7 → при этом сценарии миграция завершится слишком поздно	7 → при этом сценарии миграция завершится слишком поздно

Допущения планирования: x для обмена ключами, x для подписей, y — значения по умолчанию профиля риска «Криптобиржа, кастодиан или кошелёк», а не данные клиента; с фактическими сроками клиента вывод может измениться.

Постквантовая зрелость: Уровень 0 из 4 — постквантовой криптографии нет

Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

Уровни: 0 — нет; 1 — есть, но не подключено; 2 — используется вне критичных путей; 3 — гибрид в критичном пути; 4 — постквантовое по умолчанию в критичных путях (корень доверия, обёртка ключей, обмен ключами в канале). Оценка по коду и манифестам.

Что делают квантово-уязвимые алгоритмы

Роль	Алгоритмы (файлы)	ID	Первый шаг
подпись транзакций и сообщений	ECDSA (6)	QSI-2026-06654	Следите за постквантовыми планами каждой сети, не используйте открытые ключи повторно и держите подписание готовым к постквантовым схемам по мере их принятия сетями
роль не определена	ECDSA (1)	QSI-2026-06653	Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема; введите уровень абстракции для криптогибкости

Роль определяется по путям файлов, именам функций и коду вокруг совпадений; проверка её подтверждает. Сначала — ключи корня доверия и обёрнутые ключи: их трудно заменить или можно записать уже сегодня.

z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Квантовый статус	Количество
слаб классически	3
уязвим (Шор)	7

Подробное описание находок: QSI-2026-06654, QSI-2026-06653

Анкета постквантовой готовности

Анкета готовности для проекта не заполнялась.

Квантовые алгоритмы, значимые для этой инвентаризации

Квантовый алгоритм	Действие	Алгоритмы из инвентаризации (строк)	Что это значит для аудита
Алгоритм Шора — дискретный логарифм на эллиптических кривых Q1: квантовые вычисления офлайн, классический доступ к жертве	взламывает	ECDSA (7)	Ключи на эллиптических кривых, по оценкам, падут раньше ключей RSA сопоставимой классической стойкости. В блокчейнах первыми под угрозой монеты, чей открытый ключ уже опубликован (повторно используемые адреса, выходы pay-to-public-key и Taproot); планируйте переход на постквантовые подписи и до этого избегайте повторного использования ключей.
Алгоритм Гровера — поиск ключа и прообразов Q1: квантовые вычисления офлайн, классический доступ к жертве	ослабляет (более длинные ключи восстанавливают запас)	RIPEMD-160 (3)	Не взлом. Ключи 256 бит (AES-256, ChaCha20) сохраняют хороший запас; AES-128 соответствует категории 1 NIST, но некоторые регуляторы требуют 256-битных ключей в квантово-устойчивых системах (см. запись AES-128). Для долгоживущих данных предпочитайте 256-битные ключи; 256-битные хеши для стойкости к прообразам менять не нужно.
Брассар–Хойер–Тапп — поиск коллизий Q1: квантовые вычисления офлайн, классический доступ к жертве	ослабляет (более длинные ключи восстанавливают запас)	RIPEMD-160 (3)	256-битные хеши (SHA-256, SHA3-256) остаются достаточными по стойкости к коллизиям; 160-битные хеши слабы уже классически (коллизии SHA-1 практичны). Где нужны категории NIST 4–5, используйте хеши на 384/512 бит.

Действие: взламывает — алгоритм нужно заменить; ослабляет — более длинные ключи или выходы восстанавливают запас; учтено в стандартных параметрах — при стандартных наборах действий не требуется; только при суперпозиционных запросах — к обычному применению неприменимо.

Ограничения и допущения

- Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.
- z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.
- osv_advisories — не проверено: no exactly pinned versions to query

План устранения проблем

QSI-2026-06654 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования ECDSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.
Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-06653 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования ECDSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.
Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-06654 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию ECDSA на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.
Сложность	high

Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.
Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема или гибридной схемы.

QSI-2026-06653 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию ECDSA на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.
Сложность	high
Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.
Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема или гибридной схемы.

Приоритеты на 30, 60 и 90 дней

30 дн.

Приоритет	ID	Действие	Тип
Нет			

60 дн.

Приоритет	ID	Действие	Тип
Нет			

90 дн.

Приоритет	ID	Действие	Тип
P3	QSI-2026-06654	Внесите использования ECDSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P3	QSI-2026-06653	Внесите использования ECDSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P4	QSI-2026-06654	Запланируйте миграцию ECDSA на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины
P4	QSI-2026-06653	Запланируйте миграцию ECDSA на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины

Проверки после устранения

ID	Повторная проверка
QSI-2026-06654	Повторите инвентаризацию после рефакторинга.
QSI-2026-06653	Повторите инвентаризацию после рефакторинга.

Использованные инструменты

Tool	Version
blockchain	1.0.0
certificates	1.1.0
chain_map	1.0.0
configs	1.1.0
dependencies	1.2.0
inventory_document	1.1.0
solidity	1.2.0
source_code	1.3.0
tls_code	1.1.0
tls_live	1.0.0
qsi-engine	1.2.0
OSV.dev API	v1

Источники и нормативные документы

Reviewed: 2026-10-13

1. A. Chailloux, M. Naya-Plasencia, A. Schrottenloher — An Efficient Quantum Collision Search Algorithm and Implications on Symmetric Cryptography (ASIACRYPT 2017; IACR ePrint 2017/847) — IACR ePrint. https://eprint.iacr.org/2017/847 (peer-reviewed article: Õ(2^{2n/5}) time, O(n) qubits, Õ(2^{n/5}) classical memory)
2. C. Chevignard, P.-A. Fouque, A. Schrottenloher — Reducing the Number of Qubits in Quantum Discrete Logarithms on Elliptic Curves (IACR ePrint 2026/280) — IACR ePrint. https://eprint.iacr.org/2026/280 (revision of a EUROCRYPT 2026 paper: 3.12n + o(n) qubits; for n = 256, 1193 qubits and 22 runs of 2^38.98 Toffoli gates)
3. C. Zalka — Grover's quantum searching algorithm is optimal (Phys. Rev. A 60, 2746, 1999; arXiv:quant-ph/9711070) — APS. https://doi.org/10.1103/PhysRevA.60.2746 (peer-reviewed article: optimal for any success probability; parallel search gains no more than splitting the space)
4. Common Vulnerability Scoring System v3.1: Specification Document — FIRST. https://www.first.org/cvss/v3.1/specification-document (final)
5. D. J. Bernstein — Cost analysis of hash collisions: Will quantum computers make SHARCS obsolete? (2009) — cr.yp.to. https://cr.yp.to/hash/collisioncost-20090823.pdf (paper dated 2009-08-23)
6. D. Litinski — How to compute a 256-bit elliptic curve private key with only 50 million Toffoli gates (arXiv:2306.08585) — arXiv. https://arxiv.org/abs/2306.08585 (preprint (2023-06-14): 6000 modules × 1152 physical qubits, one key per 10 minutes under its architecture assumptions)
7. FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM) — NIST. https://csrc.nist.gov/pubs/fips/203/final (final (August 2024))
8. FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA) — NIST. https://csrc.nist.gov/pubs/fips/204/final (final (August 2024))
9. FIPS 205 — Stateless Hash-Based Digital Signature Standard (SLH-DSA) — NIST. https://csrc.nist.gov/pubs/fips/205/final (final (August 2024))
10. G. Brassard, P. Høyer, A. Tapp — Quantum Algorithm for the Collision Problem (LATIN '98; arXiv:quant-ph/9705002) — Springer / arXiv. https://arxiv.org/abs/quant-ph/9705002 (peer-reviewed article: collisions of r-to-one functions in O((N/r)^{1/3}) expected evaluations)
11. J. Proos, C. Zalka — Shor's discrete logarithm quantum algorithm for elliptic curves (Quantum Inf. Comput. 3(4), 2003; arXiv:quant-ph/0301141) — Quantum Information & Computation. https://doi.org/10.26421/QIC3.4-3 (peer-reviewed article)
12. L. K. Grover — A fast quantum mechanical algorithm for database search (STOC 1996) — ACM. https://doi.org/10.1145/237814.237866 (peer-reviewed article)
13. M. Amy et al. — Estimating the cost of generic quantum pre-image attacks on SHA-2 and SHA-3 (SAC 2016; arXiv:1603.09383) — Springer / arXiv. https://arxiv.org/abs/1603.09383 (peer-reviewed article: SHA-256 about 2^153.8 surface-code cycles on 2^12.6 logical qubits; SHA3-256 about 2^146.5 cycles on 2^20)
14. M. Cain et al. — Shor's algorithm is possible with as few as 10,000 reconfigurable atomic qubits (arXiv:2603.28627) — arXiv. https://arxiv.org/abs/2603.28627 (preprint (2026-03-30): P-256 in a few days with 26,000 physical neutral-atom qubits; RSA-2048 one to two orders of magnitude longer)
15. M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018) — IEEE. https://doi.org/10.1109/MSP.2018.3761723 (peer-reviewed article; source of the x + y > z migration inequality)
16. M. Roetteler, M. Naehrig, K. Svore, K. Lauter — Quantum resource estimates for computing elliptic curve discrete logarithms (ASIACRYPT 2017) — IACR / arXiv. https://arxiv.org/abs/1706.06752 (peer-reviewed article: at most 9n + 2⌈log2 n⌉ + 10 qubits and 448 n^3 log2 n + 4090 n^3 Toffoli gates)
17. NIST IR 8547 — Transition to Post-Quantum Cryptography Standards — NIST. https://csrc.nist.gov/pubs/ir/8547/ipd (initial public draft (November 2024); proposes deprecating quantum-vulnerable public-key algorithms after 2030 and disallowing them after 2035 — dates may change in the final version)
18. NIST — Post-Quantum Cryptography Standardization: Evaluation Criteria, Security (Call for Proposals, Section 4.A.5) — NIST. https://csrc.nist.gov/Projects/Post-Quantum-Cryptography/Post-Quantum-Cryptography-Standardization/Evaluation-Criteria/Security-(Evaluation-Criteria) (security categories: AES-128 key search 2^170/MAXDEPTH quantum gates, AES-192 2^233/MAXDEPTH, AES-256 2^298/MAXDEPTH; MAXDEPTH 2^40–2^96)
19. P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997) — SIAM. https://doi.org/10.1137/S0097539795293172 (peer-reviewed article)
20. R. Babbush et al. — Securing Elliptic Curve Cryptocurrencies against Quantum Vulnerabilities: Resource Estimates and Mitigations (arXiv:2603.28846) — arXiv. https://arxiv.org/abs/2603.28846 (preprint (2026-03-30, v2 2026-04-15): 256-bit ECDLP with < 1200 logical qubits and < 90 M Toffoli gates (or < 1450 and < 70 M); < 500,000 physical qubits at 10^-3 error, minutes)

21. S. Jaques, M. Naehrig, M. Roetteler, F. Virdia — Implementing Grover oracles for quantum key search on AES and LowMC (EUROCRYPT 2020; arXiv:1910.01700) — Springer / arXiv. https://arxiv.org/abs/1910.01700 (peer-reviewed article: lower cost estimates for the AES key searches that define the NIST categories)

Приложения

A. Криптографическая инвентаризация

Алгоритм	Параметр	Расположение	Квантовый статус	Классический статус
RIPEMD-160	RIPEMD-160	src/descriptor/dsl.rs:726	слаб классически	устаревающий
RIPEMD-160	RIPEMD-160	src/descriptor/mod.rs:189	слаб классически	устаревающий
RIPEMD-160	RIPEMD-160	src/descriptor/policy.rs:1000	слаб классически	устаревающий
ECDSA	secp256k1	src/descriptor/dsl.rs:69	уязвим (Шор)	допустимо
ECDSA	secp256k1	src/descriptor/mod.rs:27	уязвим (Шор)	допустимо
ECDSA	secp256k1	src/keys/mod.rs:29	уязвим (Шор)	допустимо
ECDSA	secp256k1	src/persist_test_utils.rs:13	уязвим (Шор)	допустимо
ECDSA	secp256k1	src/wallet/mod.rs:42	уязвим (Шор)	допустимо
ECDSA	secp256k1	src/wallet/signer.rs:101	уязвим (Шор)	допустимо
ECDSA	secp256k1	src/wallet/utils.rs:13	уязвим (Шор)	допустимо

B. JSON

qsi.report/1 · SHA-256 b5aca581ea6518105c006631bb85a071e969e4986c59649d45daa4f0d385be01